

1 OBJETIVO

Este laboratorio marca el inicio de la implementación de un **Sistema de Gestión de Seguridad de la Información (SGSI)** siguiendo la norma **ISO/IEC 27001** en la organización que se les ha asignado (tienda, banco, universidad o hospital).

Ustedes forman parte de un **equipo de consultoría en ciberseguridad** contratado para la implantación del SGSI. El objetivo de esta primera actividad es **realizar el análisis de riesgos** de la infraestructura tecnológica de la organización, identificando activos, amenazas, vulnerabilidades y riesgos asociados.

Al finalizar la práctica, el estudiante estará en capacidad de:

- Aplicar el enfoque de análisis de riesgos de ISO/IEC 27001 e ISO/IEC 27005.
- Utilizar herramientas técnicas para identificar exposición de activos y vulnerabilidades.
- Evaluar y clasificar riesgos según *probabilidad* e *impacto*.
- Elaborar un informe técnico con hallazgos y priorización de riesgos.

2 LECTURAS PREVIAS

- Presentaciones de clase
- ISO/IEC 27005 – Gestión de riesgos de seguridad de la información (resumen oficial): <https://www.iso.org/standard/80585.html>
- Guía oficial de Nmap: <https://nmap.org/book/man.html>
- Guía de OpenVAS (Greenbone): <https://greenbone.github.io/docs/latest/>
- Guía de Nikto: <https://highon.coffee/blog/nikto-cheat-sheet/>
- Introducción a redes segmentadas y zonas de seguridad: https://www.cisco.com/c/en/us/td/docs/security/firewalls/segmenting_networks.html

3 INFORMACIÓN BÁSICA

Cada grupo ha recibido el contexto de la organización con la que debe trabajar, las credenciales y el instalador de la VPN para conectarse a la infraestructura asignada. **Importante:** la VPN **solo funciona desde la red de la universidad**. El acceso está restringido a los recursos de su grupo.

Además, los gerentes de cada organización han proporcionado la siguiente información sobre la infraestructura. *Parte del ejercicio consiste en descubrir activos no documentados:*

- **DMZ:**

- Servidor web conectado a la base de datos.
- Servidor FTP.
- Servidor mail.

- **Red Interna:**

- Servidor de base de datos.
- SIEM (Wazuh).

- **Red Adicional:**

- Se conoce un servidor en .30.20; se desconoce el resto.

Toda la infraestructura está regulada por un firewall pfSense que segmenta y controla el tráfico entre redes. El servidor web en DMZ se conecta con la base de datos en la red interna. A cada grupo se le entregó una **Máquina Virtual (VM) Kali Linux** con acceso a toda la infraestructura a través de la VPN.

Restricción de alcance (*Scope*)

Prohibido salir del alcance. El alcance de los escaneos está limitado únicamente a la infraestructura asignada a su grupo. Cualquier intento de escanear, interactuar o acceder a redes/direcciones IP fuera del alcance será detectado. Si se detecta actividad fuera del alcance, la calificación del laboratorio será **0 inmediato** para todo el grupo, sin posibilidad de recuperación.

Advertencias Adicionales (*Warning*)

Denegación Accidental de Servicios Durante las prácticas interactuarán directamente con la infraestructura del negocio desde la VM Kali provista. Si estas interacciones resultan en denegación de servicios existirán penalizaciones:

- **Apagado de HARDWARE:** Calificación inmediata de 0 en el laboratorio sin posibilidad de recuperación.
- **Apagado de VMs:** Penalización de 1 unidad en calificación del laboratorio.
- **Apagado de SERVICIOS:** No representará una penalización directa en la nota. Pero se insiste en la importancia de no atentar contra los sistemas que se están auditando.

Nota: Cualquier inconveniente presentado con la infraestructura deberá ser comunicado en horarios razonables al asistente graduado por discord para su solución.

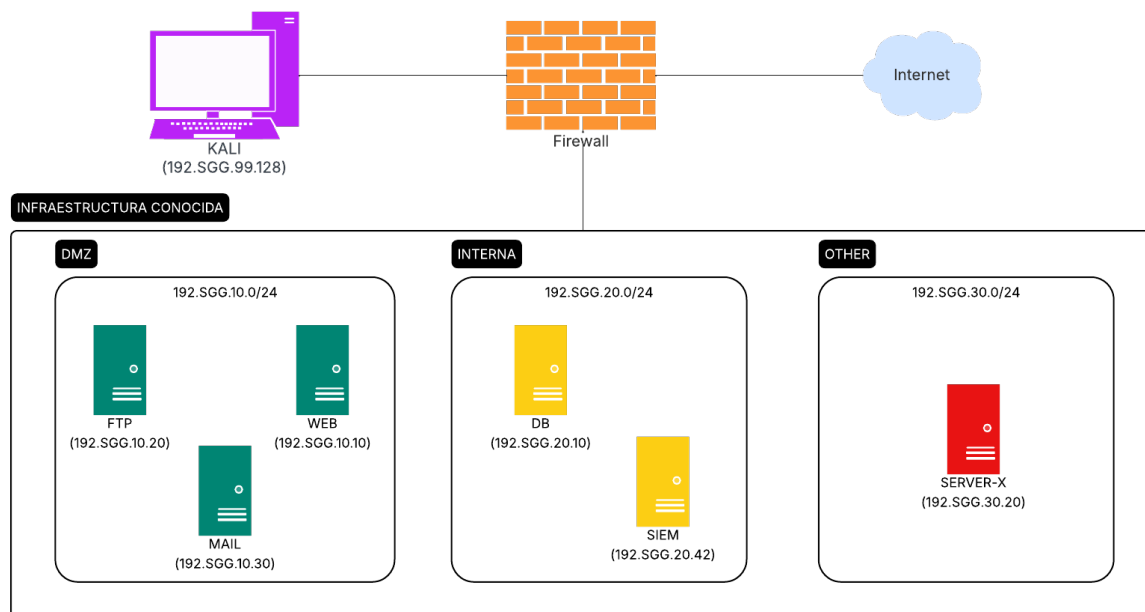
Restricciones Técnicas (*VPN, SSH y RDP*)

La VPN asignada a cada grupo presenta conflictos si es accedida por más de un usuario simultáneamente. Se recomienda organizarse bien para evitar esto.

4 PROCEDIMIENTO

Este laboratorio se realiza desde la **máquina Kali** asignada. La actividad incluye reconocimiento activo, identificación de servicios/puertos, detección de vulnerabilidades y elaboración de un *mapa de riesgos*.

Diagrama



Esquema de direccionamiento IP

El esquema general es:

192.1GG.XX.YY

donde:

- **GG**: número de grupo (01–30).
- **XX**: segmento de red (10 = DMZ, 20 = Interna, 30 = Red adicional).
- **YY**: servidor dentro del segmento.

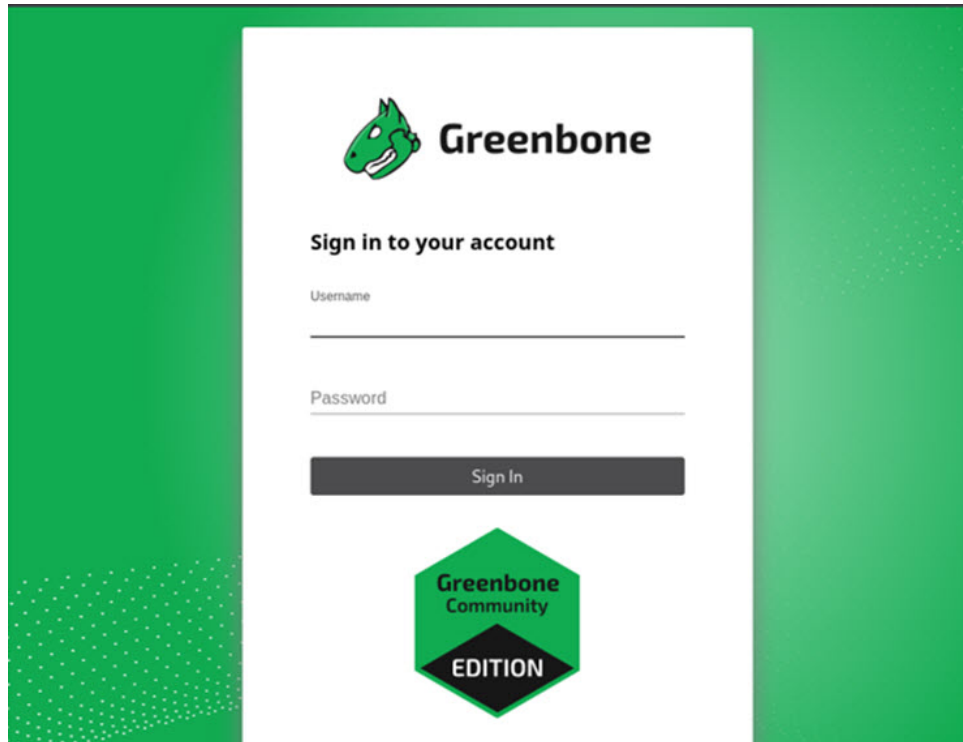
Ejemplo: 192.101.10.10 corresponde al servidor web en la DMZ del Grupo 1.

Nota: El número de grupo es el mismo nombre de su VPN. No necesariamente el número de grupo de Bloque Neón.

Herramientas

- **OpenVAS (Greenbone)** Esta herramienta ya se encuentra acondicionada en su máquina Kali, una vez instalado accederá mediante la interfaz web en el enlace `https://localhost:9392/`. Si no puede acceder asegúrese de ejecutar el comando `sudo gvm-start`.

Nota: Esta herramienta consume mucha RAM. La VM tiene recursos limitados, por lo que se recomienda detenerla al finalizar su uso.



- **Nmap** Con esta herramienta se pueden realizar diversos tipos de escaneos a nivel de red: ARP, ICMP, TCP, UDP, detección de firewall. También permite la detección de servicios y sistemas operativos.

```
Windows PowerShell
PS C:\> nmap -sVC -O -T4 scanme.nmap.org
Starting Nmap 7.96 ( https://nmap.org ) at 2025-05-07 12:17 Central Daylight Time
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.091s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
| 1024 ac:00:a0:1a:82:ff:cc:55:99:dc:67:2b:34:97:6b:75 (DSA)
| 2048 20:3d:2d:44:62:2a:b0:5a:9d:b5:b3:05:14:c2:a6:b2 (RSA)
| 256 96:02:bb:5e:57:54:1c:4e:45:2f:56:4c:4a:24:b2:57 (ECDSA)
|_ 256 33:fa:91:0f:e0:e1:7b:1f:6d:05:a2:b0:f1:54:41:56 (ED25519)
25/tcp    filtered smtp
80/tcp    open  http      Apache httpd 2.4.7 ((Ubuntu))
|_ http-title: Go ahead and ScanMe!
|_ http-favicon: Nmap Project
|_ http-server-header: Apache/2.4.7 (Ubuntu)
5431/tcp  filtered park-agent
9929/tcp  open  nping-echo Nping echo
31337/tcp open  tcpwrapped
Device type: general purpose|router
Running: Linux 5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 5.0 - 5.14, MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 15 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 28.46 seconds
PS C:\>
```

- **Nikto** Esta es una herramienta exclusiva para vulnerabilidades web. En ella se pueden conocer vulnerabilidades conocidas, información del servidor, encabezados HTTP, certificado, tecnologías empleadas entre otros diversos outputs que genera. Es ligera, fácil de entender y arroja resultados mientras se escanea.

```
(kali@222vm) - [~]
$ nikto -h 192.168.40.168
- Nikto v2.1.6
-----
+ Target IP: 192.168.40.168
+ Target Hostname: 192.168.40.168
+ Target Port: 80
+ Start Time: 2023-09-14 22:44:28 (GMT-4)
-----
+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10
+ The anti-clickjacking X-Frame-Options header is not present.
+ The X-XSS-Protection header is not defined. This header can hint to the user agent to protect against some forms of XSS
```

5 TRABAJO PROPUESTO

En calidad de consultores encargados de implantar el SGSI de la organización asignada, realicen un **análisis de riesgos** ajustado a ISO/IEC 27001/27005:

- Descubran y documenten **todos los activos** presentes.
- Identifiquen **servicios y puertos** expuestos por cada servidor notificado por el gerente.

- Detecten **vulnerabilidades** con OpenVAS y relacionen hallazgos técnicos con **riesgos** (probabilidad/impacto).
- Elaboren un **informe técnico** con todas las vulnerabilidades encontradas y un **resumen ejecutivo** para directivos, con recomendaciones iniciales de tratamiento.

6 ENTREGABLES

- **PDF** no-mayor a 20 páginas con: inventario de activos y servicios; vulnerabilidades y clasificación de riesgo; recomendaciones.
- **Informe Técnico** con todas las vulnerabilidades detectadas en cada servidor. Se les adjuntará una plantilla que deberán llenar.
- **Evidencias:** reportes/exportaciones de **Nmap** y **OpenVAS**.
- Envío en un **.zip** nombrado **Lab1-GXX.zip** (donde **XX** es el número de grupo).

7 EVALUACIÓN

Criterio	Valor
Informe técnico (claridad, coherencia, análisis)	30 %
Resumen Ejecutivo (claridad, coherencia, análisis)	30 %
Evidencia y uso de Nmap	10 %
Evidencia y uso de OpenVAS	10 %
Identificación y priorización de riesgos	20 %
Total	100 %

8 HISTORIAL DE REVISIONES

Fecha	Autor(es)	Versión	Referencia de Cambios
15/08/2025	Juan Andrés Ariza	1.0	Versión inicial del laboratorio
26/01/2026	Julián Contreras	1.1	Aclaraciones

REVISOR(ES)

Nombre	Cargo	Institución
Carlos Lozano	Profesor Asistente del Departamento de Ingeniería de Sistemas y Computación	Universidad de los Andes